



DAS Policy

No:
2100-01

Password Policy

Effective:
October 11, 2023

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

This policy addresses the use, management, and control of passwords used to access Ohio Department of Administrative Services **(DAS)-Managed System Assets**. The first occurrence of a defined term in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV.

II. Scope

The scope of this policy includes all user accounts (or any forms of access that support or require a password) on any DAS-Managed System Assets.

III. Policy

DAS is issuing this policy to ensure compliance with related state policies and to protect DAS-Managed System Assets. DAS IT systems managers shall ensure that passwords for DAS-Managed System Assets adhere to the following requirements:

- A. **Password Standards**: The use, management, and control of passwords that are used to access DAS-Managed System Assets shall conform to the requirements outlined in DAS-ITS-2100-01-A, "Password Standard for Organizational **Users**," and DAS-ITS-2100-01-B, "Password Standard for Non-Organizational Users."
- B. **Compromised Passwords**: Immediately deactivate user accounts associated with compromised passwords, maliciously or by accident. All instances of compromised passwords must be immediately reported by contacting the Customer Service Center at CSC@ohio.gov, 614-644-6860 or 877-644-6860.

- C. **Browser-Based Save Password Configuration Setting:** *Save Password Options* shall not be allowed. If an information system's browser-based save password feature cannot be disabled, users shall be instructed not to use that option.
- D. **Legacy or Non-standard Systems:** DAS IT systems managers shall identify systems that are unable to support *User IDs*, passwords, or other security measures for access to administrative level services and develop procedures to offset this risk.
1. DAS IT systems managers shall ensure that administrators of such systems are both aware of the risk and trained on how to safeguard such systems.
 2. Upgrades to these systems shall involve the implementation of security measures, including user IDs and passwords, as outlined in this policy, and defined in DAS IT Standard DAS-ITS-2100-01-A, "Password Standard for Organizational Users," and DAS IT Standard DAS-ITS-2100-01-B, "Password Standard for Non-Organizational Users."
- E. **Password Masking:** Passwords shall not be displayed to the user in their entirety; passwords shall be masked or obscured from view when entered. It is permissible to program systems to briefly display individual keystrokes.
- F. **Default Passwords:** Default application and system passwords shall be reset before the deployment of any system or application.

IV. Definitions

- A. *DAS-Managed System Asset*. Information, hardware, software and services required to support state business, and identified during the risk assessment process as assets that need to be protected. Primary responsibility for managing these system assets may be assigned to DAS OIT personnel or other outside entities.
- B. *Save Password Option*. An option on some systems that, when enabled, allows the user the choice of whether to have the user password memorized by the system so that it will not need to be re-entered upon subsequent access.
- C. *Users*. An individual or (system) process authorized to access an information system.¹
- D. *User ID*. Unique symbol or character string used by an information system to identify a specific user.²

¹ FIPS 200, Minimum Security Requirements for Federal Information and Information Systems." U.S. Department of Commerce National Institute of Standards and Technology, March 2006.
<<http://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.200.pdf>>.

² "CNSS Instruction No. 4009, National Information Assurance (IA) Glossary," Committee on National Security Systems, 6 April 2015 < http://www.ncsc.gov/publications/policy/docs/CNSSI_4009.pdf>.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02, Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies/its-sec-02-enterprise-security-controls-framework
DAS IT Standard DAS-ITS-2100-01-A, Password Standard for Organizational Users	https://das.ohio.gov/technology-and-strategy/policies/das-its-2100-01-a
DAS IT Standard DAS-ITS-2100-01-B, Password Standard for Non- Organizational Users	https://das.ohio.gov/technology-and-strategy/policies/das-its-2100-01-b-password-standard-for-non-organizational-users

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street
Columbus, Ohio 43215

614.644.9391 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

Additional information regarding the Office of Information Security & Privacy may be found online at <https://das.ohio.gov/technology-and-strategy/information-security-privacy>.

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
12/01/2009	New policy for DAS, replaces OIT policy dated 6/29/07.
12/05/2012	Policy reissued under Director Robert Blair.
07/12/2017	Policy revised to align with current security practices.
12/04/2018	Conducted scheduled maintenance review, no changes were made to the policy as a result.
01/15/2020	Updated the policy template.
05/28/2021	Conducted routine maintenance review of citations and references.
10/11/2023	Modified the save password options requirement. Updated the policy template.